SALESFORCE ADMIN COURSE — EPISODE 33

Login Security, Password Policies & MFA

Complete Guide — Login Hours, Profile IP Ranges vs. Trusted IPs, Authenticator & High Assurance

- 🔐 Password Policies & Lockout Rules
- 🕐 Login Hours (Profile-Level Restrictions)
- 🌐 Login IP Ranges vs. Trusted IP Ranges
- 🛡️ Multi-Factor Authentication (MFA)
- 🔑 Phishing-Resistant WebAuthn Keys & Passkeys
- 🏆 High Assurance Session Security

EPISODE	DURATION	LEVEL
33 of Series	~30 Minutes	Intermediate to Advanced

DOMAIN

Zero Trust Authentication

📋 Table of Contents

1. Introduction & Course Context — 0:00 – 1:00
2. Password Policies: Complexity, History & Lockout — 1:00 – 4:00
3. Login Hours: Restricting WHEN Users Can Log In — 4:00 – 6:30
4. Login IP Ranges vs. Trusted IP Ranges (The Big Difference) — 6:30 – 9:30
5. Multi-Factor Authentication (MFA) & Modern Threats — 9:30 – 12:00
6. MFA Verification Methods: Push, Keys, Passkeys & TOTP — 12:00 – 15:30
7. Session Security Levels: Standard vs. High Assurance — 15:30 – 17:00
8. Hands-on Demo: Configuring Mon–Fri 9am–6pm Login Hours — 17:00 – 21:00
9. Hands-on Demo: IP Restrictions & MFA Walkthrough — 21:00 – 25:30
10. Summary & Key Takeaways — 25:30 – End

SECTION 1

Introduction & Course Context

⏱ 0:00 – 1:00

Welcome back to the **Salesforce Admin Course!** In Episode 32, we learned how to create and manage Salesforce Users, User Licenses, and how to freeze or deactivate accounts.

Now let's ask a critical cybersecurity question: **Suppose a malicious actor steals an employee's username and password through a phishing email or data breach. Is password authentication alone enough to protect your enterprise org?**

Absolutely not! That is why Salesforce implements a robust, multi-layered login defense mechanism: **Password Policies**, **Login Hours**, **Login IP Ranges**, and mandatory **Multi-Factor Authentication (MFA)**!

SECTION 2 — PASSWORD SECURITY

Password Policies & Brute-Force Defenses

⏱ 1:00 – 4:00

Configured under **Setup ➔ Password Policies** (or at the individual Profile level):

Minimum Length

Default is 8 characters. Admins can enforce 10, 12, or 15 characters.

Complexity

Enforces mix of Alpha, Numeric, Uppercase, Lowercase, and Special characters.

Password History

Remembers 1 to 24 previous passwords; prevents rotating back to old ones.

Expiration

Forces password reset every 30, 60, 90 days, or Never (service accounts).

Max Failed Attempts

Locks the account after 3, 5, or 10 invalid attempts to block brute-force scripts.

Lockout Period

Sets temporary lockout timer (15, 30, 60 mins) or requires admin unlock.

SECTION 3 — PROFILE RESTRAINT

Login Hours: Restricting WHEN Users Can Log In

⏱ 4:00 – 6:30

📌 WHAT ARE LOGIN HOURS?

Login Hours are configured at the **Profile level** to strictly dictate the days of the week and hours of the day when users assigned to that Profile are allowed to access Salesforce.

💡 MID-SESSION EXPIRATION BEHAVIOR

If an employee is already logged in when their allowed Login Hours expire (e.g., at 6:01 PM), Salesforce allows them to view their current open page, but **any click, edit, save, or navigation triggers an immediate session termination**!

SECTION 4 — EXAM FAVORITE

Login IP Ranges vs. Trusted IP Ranges

⏱ 6:30 – 9:30

Criterion	🔒 Profile Login IP Ranges	🏢 Org Trusted IP Ranges
Where Configured?	**Profile Level** (Setup ➔ Profiles ➔ [Profile])	**Org Level** (Setup ➔ Network Access)
Purpose	Restricts **WHERE** users can log in from	Bypasses **Identity Challenges**
If user logs in outside range?	❌ **LOGIN IS DENIED / BLOCKED**	⚠️ Login allowed, but **Identity Verification challenge** required
Typical Use Case	Force Call Center reps to log in *only* from office VPN	Whitelist HQ office IPs so workers skip SMS/email OTPs

⚠️ EXTREME DANGER: ADMIN LOCKOUT RISK

Never enter an unverified, random IP address into your **System Administrator Profile** Login IP Ranges! If you enter an IP that doesn't match your network, you will lock yourself out of your org entirely!

SECTIONS 5 & 6 — MANDATORY ENFORCEMENT

Multi-Factor Authentication (MFA) & Verification Methods

⏱ 9:30 – 15:30

🔑 THE MFA FORMULA

MFA = Something You Know (Username & Password) **+ Something You Have / Are** (Authenticator app, biometric passkey, or physical FIDO2 key).

Even if an attacker buys your employee's password on the dark web, they cannot enter Salesforce without approving the secondary verification prompt on the employee's physical device!

The 4 Supported MFA Verification Methods:

💻

1. Built-in Authenticator

Biometrics & Passkeys: Touch ID, Face ID, Windows Hello. **Phishing-Resistant!**

🔑

2. Physical Security Key

Hardware USB/NFC keys (e.g., YubiKey) using WebAuthn/FIDO2. **Phishing-Resistant!**

📱

3. Salesforce Authenticator

Mobile push notification: tap *"Approve"* on your phone with location context.

🔢

4. Third-Party TOTP Apps

Google Authenticator, Microsoft Authenticator, Authy generating rotating 6-digit codes.

SECTION 7 — SESSION GOVERNANCE

Session Security Levels: Standard vs. High Assurance

⏱ 15:30 – 17:00

Under **Setup ➔ Session Settings**, Salesforce categorizes sessions into two tiers:

TIER 1

Standard Session

Granted after basic username + password verification. Allows normal day-to-day navigation of standard objects.

TIER 2

High Assurance Session

Requires Multi-Factor Authentication (MFA). Admins can mandate High Assurance sessions before allowing sensitive actions like accessing Reports export, editing Apex, or accessing connected apps!

SECTIONS 8 & 9 — STEP-BY-STEP HANDS-ON

Hands-on Demos: Login Hours & MFA Flow

⏱ 17:00 – 25:30

Demo 1: Configure Mon–Fri 9am–6pm Login Hours

1. Go to ⚙️ **Setup ➔ Profiles** and select the *Sales User Profile*.
2. Scroll to the **Login Hours** section and click **Edit**.
3. Set Monday through Friday: **Start Time: 9:00 AM**, **End Time: 6:00 PM**.
4. Set Saturday and Sunday: Leave as empty or *No Access*.
5. Click **Save**. Anyone assigned to this profile is now strictly locked out on weekends and outside working hours! 🎉

Demo 2: The MFA Push Notification Experience

1. User navigates to `login.salesforce.com` and enters Username + Password.
2. Salesforce pauses and displays: *"Check your mobile device"*.
3. The **Salesforce Authenticator app** rings on the user's phone showing: Requesting User, Client, Location, and IP.
4. User clicks **Approve**.
5. The browser tab automatically completes the handshake and opens Lightning Experience in a **High Assurance Session**!

🎯 Key Takeaways from Episode 33

01

Password Policies govern length (min 8), complexity, expiration, history, and automatic lockout after invalid attempts.

02

Login Hours (Profile-level) restrict the exact days and time windows users can access Salesforce.

03

Login IP Ranges (Profile-level) **BLOCK** logins outside the range; **Trusted IP Ranges** (Org-level) merely waive verification challenges.

04

MFA is mandatory for Salesforce access, stopping credential theft, phishing, and account takeovers.

05

Phishing-Resistant MFA: Built-in authenticators (Touch ID, Windows Hello) and physical security keys (YubiKey).

06

High Assurance Sessions are created via MFA, allowing organizations to protect highly sensitive admin actions.

COMING UP NEXT — EPISODE 34

Profiles, Permission Sets & Permission Set Groups

Move from "Can they enter?" to "What can they DO?" — Master modern permission-set-led authorization!